



1. Threat Hunting Methodologies

Introduction to Threat Hunting

Threat hunting is a **proactive cybersecurity activity** where security analysts actively search for hidden threats, malicious activities, or attackers inside a network before automated tools generate alerts.

Goals of Threat Hunting

- Detect advanced persistent threats (APTs)
- Identify insider threats
- Find malware or unauthorized access
- Reduce attacker dwell time
- Improve SOC detection capabilities

Proactive Threat Hunting

Proactive hunting means actively searching for suspicious activity without waiting for alerts.

Example

An analyst suspects attackers may misuse valid credentials.

The analyst hunts for:

- Unusual login times
- Privilege escalation
- Multiple failed login attempts
- Logins from unusual locations

Hypothesis-Driven Hunting

Threat hunters create hypotheses based on:

- Threat intelligence
- Known attacker behaviors
- Recent incidents
- Security gaps

Example Hypothesis

“An attacker may be using compromised administrator accounts for privilege escalation.”

Hunting Process

1. Define hypothesis
2. Collect relevant logs
3. Analyze anomalies
4. Validate findings

Threat Hunting vs Incident Response



Threat Hunting

Proactive

Searches for hidden threats

Analyst-driven

Focuses on discovery

Continuous activity

Incident Response

Reactive

Responds after detection

Alert-driven

Focuses on containment

Event-based activity

Threat Hunting Frameworks

A. SqRR Framework

SqRR stands for:

Phase	Description
Search	Search for suspicious indicators
Query	Create queries for datasets
Retrieve	Retrieve evidence and logs
Respond	Contain and remediate threats

Example

- Search: Failed login spikes
- Query: SIEM query for Event ID 4625
- Retrieve: User activity logs
- Respond: Disable compromised account

B. TaHiTI Framework

TaHiTI = **T**argeted **H**unting integrating **T**hreat **I**ntelligence

Key Features

- Uses threat intelligence feeds
- Maps attacker TTPs
- Focuses on known adversaries
-

Workflow

1. Gather threat intelligence
2. Identify relevant TTPs
3. Hunt across systems



4. Analyze evidence
5. Improve detections

Example

Using IOC feeds to detect:

- Malicious IP addresses
- Suspicious domains
- Malware hashes

MITRE ATT&CK in Threat Hunting

MITRE ATT&CK is a framework containing:

- Tactics
- Techniques
- Procedures (TTPs)

Threat hunters use ATT&CK to:

- Understand attacker behavior
- Map detections
- Create hunting queries

Common ATT&CK Techniques

Technique ID Name		Description
T1078	Valid Accounts	Misuse of legitimate credentials
T1566	Phishing	Email-based attacks
T1210	Exploitation of Remote Services	Exploiting vulnerable services
T1059	Command and Scripting Interpreter PowerShell or shell abuse	
T1021	Remote Services	Lateral movement

Data Sources for Threat Hunting

Threat hunting requires collecting data from multiple systems.

A. EDR Logs

Endpoint Detection and Response tools provide:

- Process execution
- File changes
- Registry modifications
- User activity

Examples

- CrowdStrike



- Microsoft Defender
- SentinelOne

B. Network Traffic

Hunters analyze:

- DNS requests
- HTTP traffic
- Packet captures
- Firewall logs

Indicators

- Beaconsing traffic
- Unusual outbound connections
- C2 communication

C. SIEM Logs

Elastic Security and Wazuh help centralize logs.

Common Logs

- Windows Event Logs
- Authentication logs
- Sysmon logs
- VPN logs

D. Threat Intelligence Feeds

Threat intelligence includes:

- IOC feeds
- Malware signatures
- Threat reports
- Adversary campaigns

Platforms

- AlienVault OTX
- VirusTotal
- MISP

Threat Hunting Process

Step 1: Define Scope

Identify:



- Systems
- Users
- Threat types

Step 2: Create Hypothesis

Example:

“PowerShell abuse may indicate malware execution.”

Step 3: Collect Data

Gather:

- Logs
- Network traffic
- EDR telemetry

Step 4: Analyze

Look for:

- Anomalies
- Rare behaviors
- Known IOC matches

Step 5: Investigate

Validate suspicious findings.

Step 6: Respond

Contain and remediate.

Step 7: Improve Detection

Create SIEM rules and detections.

2. Advanced SOAR Automation

1. Introduction to SOAR

SOAR stands for:

Component	Meaning
S	Security
O	Orchestration
A	Automation
R	Response



SOAR platforms automate repetitive SOC tasks.

SOAR Components

A. Orchestration

Integrates multiple security tools.

Example

- SIEM
- Firewall
- EDR
- Ticketing system

SOAR connects them into one workflow.

B. Automation

Automates repetitive actions.

Examples

- Auto-ticket creation
- IOC enrichment
- IP blocking
- Malware scanning

C. Response

Performs containment actions.

Examples

- Disable user account
- Isolate endpoint
- Block malicious IP

Playbook Development

What is a Playbook?

A predefined workflow for incident handling.

Example: Phishing Playbook

Workflow

1. Detect suspicious email
2. Extract URLs
3. Check VirusTotal reputation
4. Block malicious domain
5. Create incident ticket
6. Notify analysts



Malware Response Playbook

Steps

1. Detect malware alert
2. Isolate host
3. Collect memory dump
4. Scan file hash
5. Remove malware
6. Generate report

SOAR Integration with SIEM/EDR

SIEM Integration

SOAR receives alerts from:

- Wazuh
- Elastic
- Splunk

EDR Integration

SOAR interacts with:

- CrowdStrike
- SentinelOne
- Defender

Example Workflow

SIEM alert → SOAR enrichment → EDR isolation

Benefits of SOAR

Benefit	Description
Faster response	Reduces response time
Reduced workload	Automates repetitive tasks
Better consistency	Standardized workflows
Improved accuracy	Fewer manual errors

3. Post-Incident Analysis and Continuous Improvement

Root Cause Analysis (RCA)

RCA identifies:

- Why the incident happened



- How it happened
- What controls failed

Fishbone Diagram

Categories:

- People
- Process
- Technology
- Environment

Used to identify contributing causes.

Lessons Learned Process

Conducted after incident closure.

Objectives

- Improve procedures
- Identify gaps
- Update playbooks
- Enhance monitoring

Lessons Learned Meeting Topics

Topic	Questions
Detection	Was detection fast enough?
Response	Were actions effective?
Communication	Was escalation clear?
Technology	Did tools work properly?

SOC Metrics and KPIs

Mean Time to Detect (MTTD)

Formula:

$$MTTD = \frac{\text{Total Detection Time}}{\text{Number of Incidents}}$$

Measures how quickly threats are detected.

Mean Time to Respond (MTTR)



$$MTTR = \frac{\text{Total Response Time}}{\text{Number of Incidents}}$$

Measures response efficiency.

Other Important Metrics

Metric	Meaning
Dwell Time	Time attacker stays undetected
False Positive Rate	Incorrect alerts generated
Resolution Rate	Incidents successfully closed
Escalation Rate	Incidents escalated to Tier 2

4. Adversary Emulation Techniques

Introduction

Adversary emulation simulates real attacker behaviors to test defenses.

Purpose:

- Validate detections
- Test SOC readiness
- Improve response workflows

Common TTPs

Technique Description

T1566	Phishing
T1210	Remote Service Exploitation
T1059	PowerShell Execution
T1021	Lateral Movement

MITRE Caldera

MITRE Caldera is an automated adversary emulation framework.

Features

- Simulates attacks
- Maps ATT&CK techniques
- Tests detections
- Automates campaigns



Example Emulation Workflow

Spearphishing Simulation

1. Send simulated phishing email
2. User clicks payload
3. Execute PowerShell
4. Attempt persistence
5. Generate SOC alerts

Red Team vs Blue Team

Team	Role
Red Team	Simulates attackers
Blue Team	Defends systems
Purple Team	Collaboration between both

5.Security Metrics and Executive Reporting

Advanced SOC Metrics

Dwell Time

$$\text{Dwell Time} = \text{Detection Time} - \text{Compromise Time}$$

Measures how long attackers remain hidden.

False Positive Rate

$$\text{False Positive Rate} = \frac{\text{False Alerts}}{\text{Total Alerts}} \times 100$$

Indicates alert accuracy.

Executive Reporting

Reports should be:

- Simple
- Visual
- Business-focused
- Non-technical

Executive Report Sections

Section	Content
Incident Summary	What happened



Section	Content
Impact	Business effect
Metrics	MTTD, MTTR, alerts
Actions Taken	Response activities
Recommendations	Improvements

Continuous Improvement

SOC teams use metrics to:

- Improve detections
- Reduce alert fatigue
- Optimize playbooks
- Enhance analyst training